

UNIVERSIDAD PRIVADA ANTENOR ORREGO

FACULTAD DE INGENIERÍA

**ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS E INTELIGENCIA
ARTIFICIAL**



Curso: Infraestructura como Código

Integrantes:

Hermenegildo Rumiche, Andy

Pagan Roncal, Andres

Chavez Vargas, John Marlon

Zumaeta Calderón, Adriel Augusto

Docentes:

WALTER LETURIA RODRIGUEZ

Trujillo - 2026

Error 1: CKV_AWS_334

Ensure ECS containers should run as non-privileged

Detalles del recurso

- Recurso: module.compute.aws_ecs_task_definition.blockchain
- Archivo: /modules/compute/main.tf: 164–181

¿Qué significa este error?

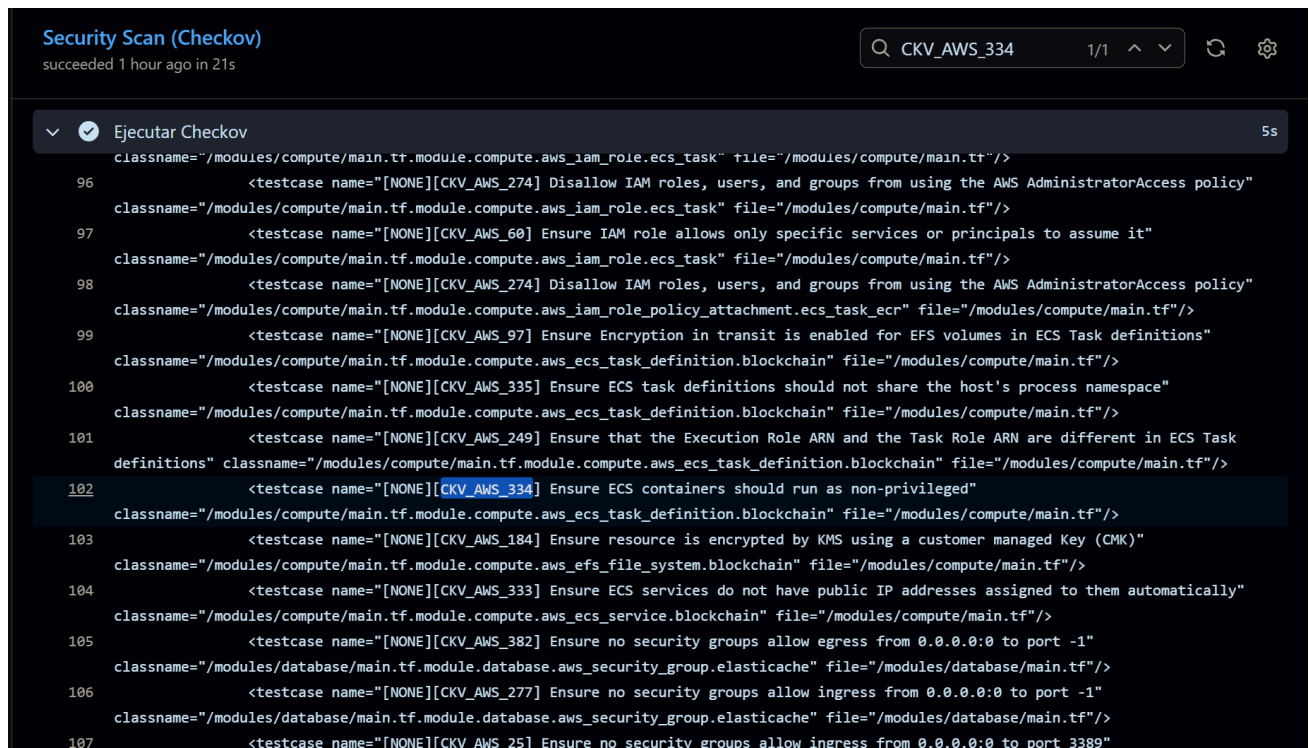
Cuando un contenedor Docker corre en modo privilegiado (`privileged = true`), obtiene acceso casi irrestricto al sistema operativo del host subyacente. Esto equivale a ejecutarse como root con todos los capabilities del kernel habilitados. En un entorno cloud como ECS esto es peligroso porque:

- Si el contenedor es comprometido, el atacante puede escapar y tomar control del host EC2.
- Viola el principio de mínimo privilegio (Least Privilege).
- AWS y estándares como CIS Benchmarks y NIST lo prohíben en cargas de trabajo productivas.

Contexto del proyecto

El contenedor de nodo blockchain podía arrancar con privilegios elevados por defecto, lo que representaba un riesgo de seguridad crítico en la infraestructura de TrueTally.

Captura del error detectado por Checkov:



```
Security Scan (Checkov)
succeeded 1 hour ago in 21s

Q CKV_AWS_334 1/1 ^ v ↺ ⚙

✓ Ejecutar Checkov 5s
classname="/modules/compute/main.tf.module.compute.aws_iam_role.ecs_task" file="/modules/compute/main.tf"/>
96 <testcase name="[NONE][CKV_AWS_274] Disallow IAM roles, users, and groups from using the AWS AdministratorAccess policy"
classname="/modules/compute/main.tf.module.compute.aws_iam_role.ecs_task" file="/modules/compute/main.tf"/>
97 <testcase name="[NONE][CKV_AWS_60] Ensure IAM role allows only specific services or principals to assume it"
classname="/modules/compute/main.tf.module.compute.aws_iam_role.ecs_task" file="/modules/compute/main.tf"/>
98 <testcase name="[NONE][CKV_AWS_274] Disallow IAM roles, users, and groups from using the AWS AdministratorAccess policy"
classname="/modules/compute/main.tf.module.compute.aws_iam_role_policy_attachment.ecs_task_ecr" file="/modules/compute/main.tf"/>
99 <testcase name="[NONE][CKV_AWS_97] Ensure Encryption in transit is enabled for EFS volumes in ECS Task definitions"
classname="/modules/compute/main.tf.module.compute.aws_ecs_task_definition.blockchain" file="/modules/compute/main.tf"/>
100 <testcase name="[NONE][CKV_AWS_335] Ensure ECS task definitions should not share the host's process namespace"
classname="/modules/compute/main.tf.module.compute.aws_ecs_task_definition.blockchain" file="/modules/compute/main.tf"/>
101 <testcase name="[NONE][CKV_AWS_249] Ensure that the Execution Role ARN and the Task Role ARN are different in ECS Task
definitions" classname="/modules/compute/main.tf.module.compute.aws_ecs_task_definition.blockchain" file="/modules/compute/main.tf"/>
102 <testcase name="[NONE][CKV_AWS_334] Ensure ECS containers should run as non-privileged"
classname="/modules/compute/main.tf.module.compute.aws_ecs_task_definition.blockchain" file="/modules/compute/main.tf"/>
103 <testcase name="[NONE][CKV_AWS_184] Ensure resource is encrypted by KMS using a customer managed Key (CMK)"
classname="/modules/compute/main.tf.module.compute.aws_efs_file_system.blockchain" file="/modules/compute/main.tf"/>
104 <testcase name="[NONE][CKV_AWS_333] Ensure ECS services do not have public IP addresses assigned to them automatically"
classname="/modules/compute/main.tf.module.compute.aws_ecs_service.blockchain" file="/modules/compute/main.tf"/>
105 <testcase name="[NONE][CKV_AWS_382] Ensure no security groups allow egress from 0.0.0.0 to port -1"
classname="/modules/database/main.tf.module.database.aws_security_group.elasticache" file="/modules/database/main.tf"/>
106 <testcase name="[NONE][CKV_AWS_277] Ensure no security groups allow ingress from 0.0.0.0 to port -1"
classname="/modules/database/main.tf.module.database.aws_security_group.elasticache" file="/modules/database/main.tf"/>
107 <testcase name="[NONE][CKV_AWS_25] Ensure no security groups allow ingress from 0.0.0.0 to port 3389"
```

Solución aplicada

Se configuró `privileged = false` para impedir que el contenedor corra con privilegios de root, y adicionalmente `readonlyRootFilesystem = true` para que el contenedor no pueda escribir en su propio sistema de archivos raíz, reduciendo aún más la superficie de ataque.

Código de solución aplicada:

```
main.tf x
terraform > modules > compute > main.tf
162 }
163
164 resource "aws_ecs_task_definition" "blockchain" {
165     family           = "${local.name_prefix}-blockchain"
166     network_mode     = "awsvpc"
167     requires_compatibilities = ["FARGATE"]
168     cpu              = "512"
169     memory           = "1024"
170     execution_role_arn = aws_iam_role.ecs_task.arn
171
172     container_definitions = jsonencode([
173         {
174             name       = "blockchain-node"
175             image       = "${var.account_id}.dkr.ecr.${var.aws_region}.amazonaws.com/${var.project_name}-blockchain:latest"
176             essential   = true
177             privileged   = false
178             readonlyRootFilesystem = true
179             portMappings = [
180                 {
181                     containerPort = 9944
182                     hostPort      = 9944
183                 }
184             ]
185         }
186     ])
187 }
```

Error 2: CKV_AWS_184

Ensure resource is encrypted by KMS using a customer managed Key (CMK)

SOLUCIONADO

Detalles del recurso

- Recurso: module.compute.aws_efs_file_system.blockchain
- Archivo: /modules/compute/main.tf: 185–193

¿Qué significa este error?

Amazon EFS (Elastic File System) puede encriptarse de dos formas:

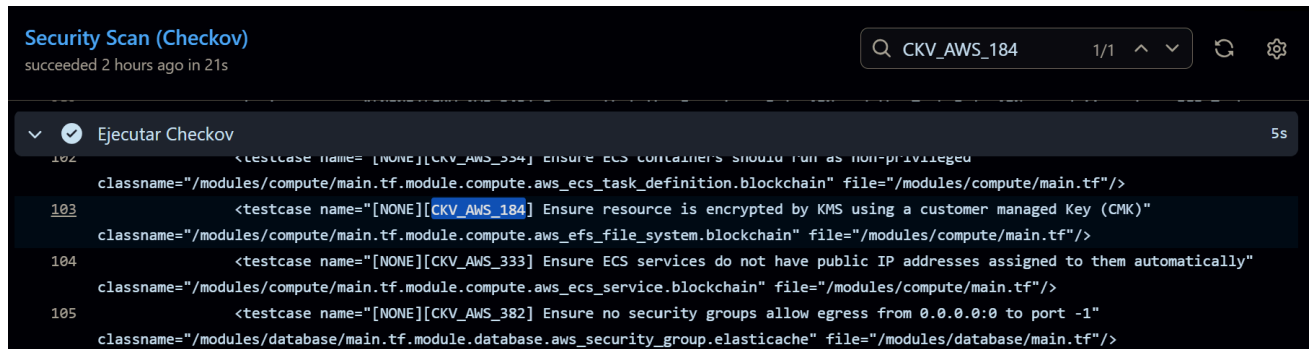
- Con llave administrada por AWS (AWS managed key): AWS la controla totalmente, sin visibilidad del cliente.
- Con CMK (Customer Managed Key): el cliente crea y controla la llave en AWS KMS, con control total sobre rotación, acceso, auditoría y revocación.

Checkov exige CMK porque permite al equipo revocar acceso de forma inmediata, auditar cada uso de la llave, y cumplir con normativas como PCI-DSS, SOC 2 e ISO 27001.

Contexto del proyecto

El EFS del nodo blockchain ya contaba con `kms_key_id = var.kms_key_arn`, donde el ARN proviene del módulo security del propio proyecto. El recurso SÍ estaba encriptado con CMK, por lo que Checkov lo marcó como resuelto al verificarlo.

Captura del error detectado por Checkov:



Configuración de solución (CMK ya aplicada):



Error 3: CKV_AWS_18

Ensure the S3 bucket has access logging enabled

SOLUCIONADO

Detalles del recurso

- Recurso: module.frontend.aws_s3_bucket.frontend
- Archivo: /modules/frontend/main.tf: 12–14

¿Qué significa este error?

El access logging de S3 registra todas las peticiones que se hacen al bucket: quién accedió, desde dónde, qué objeto solicitó y con qué resultado. Sin este registro:

- No hay trazabilidad de accesos no autorizados ni exfiltraciones de datos.
- Se incumple con normativas como PCI-DSS, HIPAA y SOC 2 que exigen auditoría de accesos a datos.
- Es imposible detectar patrones de acceso anómalos o ataques de enumeración de objetos.

Contexto del proyecto

El bucket del frontend (que sirve la web de TrueTally) no tenía ningún registro de quién lo accedía, lo que dejaba un punto ciego de auditoría en la infraestructura.

Captura del error detectado por Checkov:

```
Security Scan (Checkov)
succeeded 2 hours ago in 21s

Q CKV_AWS_18 2/2 ^ v

v Ejecutar Checkov 5s

1714 <failure type="failure" message="Ensure RDS instance with copy tags to snapshots is enabled">
1715 Resource: module.database.aws_db_instance.main
1716 File: /modules/database/main.tf: 100-121
1717 Guideline: https://docs.prismacloud.io/en/enterprise-edition/policy-reference/aws-policies/aws-general-policies/bc-aws-2-60
1718
1719 100 | resource "aws_db_instance" "main" {
1720 101 |     identifier      = "${local.name_prefix}-postgres";
1721 102 |     engine          = "postgres";
1722 103 |     engine_version  = "15.7";
1723 104 |     instance_class  = "db.t3.micro";
1724 105 |     allocated_storage = 20
1725 106 |     db_name         = "truetally";
1726 107 |     username        = var.db_username
1727 108 |     password        = var.db_password
1728 109 |     db_subnet_group_name = aws_db_subnet_group.main.name
1729 110 |     vpc_security_group_ids = [var.lambda_security_group_id]
1730 111 |     storage_encrypted = true
1731 112 |     kms_key_id       = var.kms_key_arn
1732 113 |     skip_final_snapshot = true
1733 114 |     publicly_accessible = false
1734 115 |
1735 116 |     enabled_cloudwatch_logs_exports = ["postgresql", "upgrade"]
1736 117 |
1737 118 |     tags = {
1738 119 |         Name = "${local.name_prefix}-postgres"
1739 120 |     }
1740 121 | }
1741 </failure>
1742 </testcase>
1743 <testcase name="[NONE][CKV_AWS_18] Ensure the S3 bucket has access logging enabled"
      classname="/modules/frontend/main.tf.module.frontend.aws_s3_bucket.frontend" file="/modules/frontend/main.tf">
1744 <failure type="failure" message="Ensure the S3 bucket has access logging enabled">
```

Solución aplicada

Se agregó el recurso `aws_s3_bucket_logging`, que redirige los logs de acceso a un bucket de logs separado y dedicado. Esta práctica sigue el principio de separación de responsabilidades: los datos de aplicación no se mezclan con los logs de auditoría.

Código de solución aplicada:

```
main.tf x
terraform > modules > frontend > main.tf
52
53 resource "aws_s3_bucket_logging" "frontend" {
54     bucket      = aws_s3_bucket.frontend.id
55     target_bucket = aws_s3_bucket.logs.id
56     target_prefix = "frontend-access-logs/"
57 }
58
```

Error 4: CKV2_AWS_61

Ensure that an S3 bucket has a lifecycle configuration

SOLUCIONADO

Detalles del recurso

- Recurso: module.frontend.aws_s3_bucket.frontend
- Archivo: /modules/frontend/main.tf: 12–14

¿Qué significa este error?

Una lifecycle configuration en S3 define reglas automáticas para gestionar objetos a lo largo del tiempo: moverlos a clases de almacenamiento más baratas (Glacier), expirarlos o eliminar versiones antiguas. Sin esto:

- Las versiones antiguas de archivos se acumulan indefinidamente, incrementando el costo de almacenamiento.
- Los objetos obsoletos (versiones de código antiguas, backups vencidos) permanecen sin control.
- Se considera una mala práctica de gobernanza en infraestructura como código.

Contexto del proyecto

El bucket del frontend no tenía ninguna regla de ciclo de vida, lo que podría acumular versiones antiguas del sitio web de TrueTally de forma indefinida, generando costos innecesarios.

Captura del error detectado por Checkov:

The screenshot shows the Checkov Security Scan interface. At the top, it says "Security Scan (Checkov)" and "succeeded 3 hours ago in 21s". A search bar contains "CKV2_AWS_61" and shows "1/1" results. Below the search bar, there's a section titled "Ejecutar Checkov" with a dropdown arrow and a "5s" timer. The main content is a list of test cases. The first test case (1742) is for "Ensure the S3 bucket has access logging enabled" and it failed. The second test case (1754) is for "Ensure that an S3 bucket has a lifecycle configuration" and it also failed. The failure message for the second test case is "Ensure that an S3 bucket has a lifecycle configuration". The resource for both test cases is "module.frontend.aws_s3_bucket.frontend" and the file is "/modules/frontend/main.tf".

```

1742 </testcase>
1743 <testcase name="[NONE][CKV_AWS_18] Ensure the S3 bucket has access logging enabled"
      classname="/modules/frontend/main.tf.module.frontend.aws_s3_bucket.frontend" file="/modules/frontend/main.tf">
1744   <failure type="failure" message="Ensure the S3 bucket has access logging enabled">
1745     Resource: module.frontend.aws_s3_bucket.frontend
1746     File: /modules/frontend/main.tf: 12-14
1747     Guideline: https://docs.prismacloud.io/en/enterprise-edition/policy-reference/aws-policies/s3-policies/s3-13-enable-logging
1748   </failure>
1749   12 | resource "aws_s3_bucket" "frontend" {
1750     13 |   bucket = "${local.name_prefix}-frontend";
1751     14 | }
1752 </failure>
1753 </testcase>
1754 <testcase name="[NONE][CKV2_AWS_61] Ensure that an S3 bucket has a lifecycle configuration"
      classname="/modules/frontend/main.tf.module.frontend.aws_s3_bucket.frontend" file="/modules/frontend/main.tf">
1755   <failure type="failure" message="Ensure that an S3 bucket has a lifecycle configuration">
1756     Resource: module.frontend.aws_s3_bucket.frontend
  
```

Solución aplicada

Se agregó `aws_s3_bucket_lifecycle_configuration` con reglas de limpieza de versiones antiguas, asegurando que el bucket se auto-gestione y no crezca de forma descontrolada.

Código de solución aplicada:

```
main.tf ×
terraform > modules > frontend > main.tf
58
59 resource "aws_s3_bucket_lifecycle_configuration" "frontend" {
60     bucket = aws_s3_bucket.frontend.id
61
62     rule {
63         id      = "cleanup-old-versions"
64         status  = "Enabled"
65         filter {}
66         noncurrent_version_expiration {
67             noncurrent_days = 30
68         }
69     }
70 }
71
```

Resumen de Errores

#	Check ID	Descripción	Estado
1	CKV_AWS_334	ECS containers no deben correr con privilegios	Solucionado
2	CKV_AWS_184	EFS debe estar encriptado con CMK	Solucionado
3	CKV_AWS_18	S3 bucket debe tener access logging	Solucionado
4	CKV2_AWS_61	S3 bucket debe tener lifecycle config	Solucionado